

Custom Authentication Flow Specification

1. Registration & Email Verification

User registers with required details.
Account status is set to Unverified.
A custom verification token is generated and delivered via email.
Verification token validity period is 5 minutes.
Only one active verification token may exist at a time.
Requesting a new token invalidates and deletes the previous token.
Expired tokens are automatically deleted.
Users must wait 2 minutes between token requests.
Maximum of 3 requests per cycle before a 1-hour lockout.
The request cycle resets automatically after cooldown.
Successful verification changes account status from Unverified to Verified.
Only verified accounts may log in.

2. Login Flow

Users may only log in with verified accounts.
Maximum of 5 failed login attempts are allowed.
Each failed login attempt is tracked and surfaced to the user.
After 5 failed attempts, the account is locked for 60 minutes.
Password reset functionality remains available during lockout.
Users receive in-app notifications after failed login attempts.
Email alerts are sent when suspicious login activity is detected.

3. Password Reset Flow

Users may request a password reset through the authentication system.
A custom reset token is delivered via email.
Reset token validity period is 5 minutes.
Only one active reset token may exist at any time.
New reset requests invalidate previous tokens.
Expired reset tokens are automatically removed.
Rate limiting mirrors the verification flow.
Users must wait 2 minutes between reset requests.
Maximum of 3 requests before a 1-hour lockout.
Users may reset passwords only with valid tokens.
Accounts remain Verified after successful password resets.

4. Security Considerations

Authentication and reset tokens must be hashed before storage.

Expired and invalid tokens are deleted immediately.

Audit logs should track token requests, login attempts, lockouts, and password resets.

Clear user-facing error messages should be provided.

Users should receive transparent notifications regarding suspicious authentication activity.

Notifications should be delivered via email and in-app messaging where applicable.

5. Recommended Enhancements

- Optional two-factor authentication (2FA).
- Session invalidation after password reset.
- IP-based suspicious activity detection.
- CAPTCHA after repeated failures.
- Secure HTTP-only authentication cookies.
- Centralized rate limiting for authentication endpoints.